

TokenPe

Complete Security Audit & Bug Report

Website: tokenpe.online | Audit Date: May 2026 | Total Issues Found: 22

Security: **STRONG**

Total Issues: 22

Critical: 2

Warnings: 3

Minor/UX: 17

1. What We Audited

Page / Endpoint	Status	Notes
tokenpe.online (Landing)	Live	Loads, SSL active, HTTPS enforced
tokenpe.online/login	Live	PIN + Google OAuth working
tokenpe.online/privacy	Live	Privacy policy present, minor gaps
tokenpe.online/terms	Live	Terms present, address incomplete
/api/whatsapp (webhook)	Review	Weak secret — critical fix needed
/api/queue/next	Secure	JWT protected, IDOR check present
/api/feedback/receive	Review	No rate limit — open to abuse
Supabase Database	Review	RLS status unconfirmed
HTTP Security Headers	Present	X-Frame, HSTS, nosniff all set
Google Indexing	Missing	Site not indexed — no sitemap found
Mobile Responsiveness	Review	Dashboard likely overflows on phones

2. Existing Security — Already Strong

Security Feature	Why It Matters
PIN + Clinic Code + Phone (triple auth)	Prevents unauthorized access even if QR code is publicly visible
JWT with HttpOnly Secure Cookies	XSS attacks cannot steal session tokens from browser
IDOR Protection on all API routes	Doctor cannot access or manipulate another clinic's data
Google OAuth SSO	Delegated to Google security including 2FA support
Security Headers (X-Frame, HSTS, nosniff)	Clickjacking, downgrade attacks, MIME sniffing all blocked
No client-side DB mutations	All database writes go through secure server-side API only
Masked phone numbers in logs	Patient phone numbers hidden in Vercel production logs
Max 3 joins per phone per clinic per day	Prevents queue flooding while allowing legitimate revisits
Different patient name required per join	Prevents same patient spamming queue with same name
Stateless JWT Architecture	No server-side session storage needed — scalable and secure

3. Security Issues Found

■ CRITICAL

Weak Webhook Secret Key

Your webhook URL uses "tokenpe_secret_123" as the security token. This is a guessable, dictionary-style password. Anyone who discovers it can send fake patient JOIN requests, flood queues with fake entries, and inject false star ratings into analytics — all without WhatsApp.

Fix: Run: `openssl rand -hex 32` in terminal. Replace `tokenpe_secret_123` everywhere in Vercel env vars and Interakt webhook URLs with the generated key.

■ CRITICAL

No Rate Limiting on Login API

The `/api/auth/login` endpoint has zero brute-force protection. An attacker can try all 10,000 possible 4-digit PINs in under 5 minutes using automated scripts. Clinic codes and phone numbers can be found on QR posters displayed publicly in clinic waiting rooms.

Fix: Add rate limiting: max 5 failed attempts per IP per 15 minutes then lockout. Use `upstash/ratelimit` package with Redis or Vercel middleware. Store failed attempt count in `clinics` table.

■ WARNING

Supabase Row Level Security (RLS) Not Confirmed

Your Supabase anon key is exposed in the frontend as `NEXT_PUBLIC_SUPABASE_ANON_KEY`. If RLS policies are not enabled, anyone with this key can query ALL patient data from ALL clinics directly through the Supabase REST API — bypassing your entire backend security.

Fix: Go to Supabase → Table Editor → RLS. Enable RLS on `patients` and `clinics` tables. Add SELECT policy: clinic can only read rows where `clinic_id` matches their session.

■ WARNING

No Input Sanitization on Patient Name and Rating

Patient names from WhatsApp flow are saved directly to Supabase without sanitization. A malicious user could enter HTML or script tags. Rating values are not validated to be strictly 1-5 integers — invalid values could corrupt analytics dashboard.

Fix: In `/api/whatsapp/route.js`: strip HTML from name before DB insert. In `/api/feedback/receive`: validate rating is `parseInt` between 1-5, reject anything else with 400 error.

■ WARNING

Subscription Plan Limits Not Enforced in API

Nothing in your backend prevents a Starter plan clinic (limit: 50 patients/day) from having 500 patients. Plan limits exist in the UI but are not validated server-side. A clinic could exploit this to get Pro/Elite features without paying.

Fix: In `/api/whatsapp/route.js` join action: check `clinic.plan` and count today's patients. If `count >= plan limit`, return error: "Daily patient limit reached. Upgrade your plan."

4. UX & Frontend Bugs

■ UX BUG

No Custom 404 Page

Visiting any invalid URL like `tokenpe.online/anything` shows a blank Next.js error page. For a professional SaaS this looks broken and unprofessional. First impressions matter especially for clinic owners who may share incorrect links.

Fix: Create `/app/not-found.js` in Next.js with a branded 404 page showing the TokenPe logo, a friendly message, and a button to go back to login or home page.

■ UX BUG

No Loading State on Login Button

If the PIN login API response is slow, the button shows no feedback. Users may click multiple times causing duplicate requests and possible session conflicts. This is especially problematic on slow Indian mobile networks.

Fix: Add loading state to login button: disable it on click, show "Signing in..." text with a spinner. Re-enable on error. Prevent double submission entirely.

■ UX BUG

No Forgot PIN Recovery Flow

If a clinic owner forgets their 4-digit PIN there is zero recovery option visible anywhere. They would need to email you manually — not scalable as you grow to 100+ clinics. This will be your most common support request.

Fix: Add "Forgot PIN?" link on login page. Flow: enter clinic code + registered phone → receive OTP via WhatsApp → set new PIN. Uses your existing WhatsApp infrastructure.

■ UX BUG

Dashboard Not Mobile Responsive

The dashboard action bar with 4 buttons (Generate QR, Add Walk-in, Call Next, hint text) was built for desktop screens. On a receptionist's phone or tablet, these buttons likely overflow or wrap incorrectly making the app hard to use.

Fix: Test dashboard on 375px width (iPhone SE). Fix action bar to stack buttons vertically on mobile. Use CSS media queries or Tailwind responsive classes. Priority: Call Next button must be easily tappable.

■ UX BUG

No Error Boundary on Dashboard

If Supabase real-time connection drops (network issue, quota exceeded), the dashboard likely crashes silently showing a blank or broken screen. The receptionist would have no idea what happened or how to recover.

Fix: Add a React error boundary component wrapping the dashboard. Show "Connection lost — Reconnecting..." banner with a manual refresh button. Also add Supabase channel error handling in the `useEffect`.

5. SEO & Discoverability Issues

■ SEO

Site Not Indexed by Google

Running "site:tokenpe.online" on Google returns zero results — your website has not been indexed. This means no doctor searching "WhatsApp queue system India" or "OPD queue management" will find you organically. You are completely invisible to search engines right now.

Fix: Go to Google Search Console → Add property → tokenpe.online → Verify via DNS. Submit sitemap at tokenpe.online/sitemap.xml. Also add Google Analytics to track visitors.

■ SEO

No sitemap.xml Found

No sitemap.xml exists at tokenpe.online/sitemap.xml. Without a sitemap, Google does not know which pages to crawl and index. Landing page, login, privacy, terms, and blog pages (if any) will not rank.

Fix: Add sitemap.xml generation to Next.js. Create `/app/sitemap.js` that exports your public pages. Next.js 13+ handles this automatically. Submit to Google Search Console once created.

■ SEO

No OG Tags for Social Media Sharing

When tokenpe.online is shared on WhatsApp, LinkedIn, or Twitter, no preview image or description card appears. For a WhatsApp-based product this is especially ironic — doctors sharing your link with colleagues get a blank ugly preview.

Fix: Add Open Graph meta tags in /app/layout.js: og:title, og:description, og:image (1200x630px TokenPe branded image), og:url. This takes 30 minutes and dramatically improves click-through rates.

6. Business & Legal Issues

■ LEGAL

No Cookie Consent Banner

Privacy policy mentions cookies and log files but there is no cookie consent banner on the website. Under India IT Rules 2021 and global best practices for SaaS, explicit consent must be collected before setting non-essential cookies.

Fix: Add a simple cookie consent banner that appears on first visit. "We use cookies to improve your experience. Accept / Learn More." Store consent in localStorage. Takes 2 hours to implement.

■ LEGAL

Incomplete Corporate Address in Terms

Terms of Service lists "Corporate Address: Mumbai, Maharashtra, India" — legally insufficient. Under Indian IT Act 2000, a complete physical address with street and PIN code is required for consumer-facing services handling health data.

Fix: Add complete address: street name, area, city, PIN code. A home address is legally acceptable for a startup. This increases trust with clinic owners reviewing your terms before subscribing.

■ BUSINESS

No Refund Policy Details or Timeline

Terms say "refund requests can be sent by email" but no timeline, conditions, or process are specified. Under Consumer Protection Act 2019, unclear refund policies are a liability. Clinic owners will ask about this before subscribing.

Fix: Add clear refund policy: "Refund requests within 7 days of payment are processed within 5-7 business days. No refunds after 7 days. Trial period does not qualify for refund." Consult a CA if needed.

■ BUSINESS

Gmail Address for Legal Contact

Privacy policy and terms use tokenpe.online@gmail.com for legal contact and data deletion requests. For a SaaS handling patient health data, a Gmail address reduces credibility and may not satisfy regulatory requirements under IT Act 2000.

Fix: Set up professional email: privacy@tokenpe.online or support@tokenpe.online using your domain. Forward to Gmail. Free on most domain providers. Takes 10 minutes.

■ BUSINESS

No Annual Billing Option

Pricing only shows monthly plans (Rs.499/mo, Rs.999/mo, Rs.1999/mo). Most SaaS businesses offer 15-20% discount for annual billing. Clinics prefer annual billing for accounting simplicity. You are leaving significant revenue on the table.

Fix: Add annual billing option: Rs.4,990/yr (save 2 months), Rs.9,990/yr, Rs.19,990/yr. Razorpay supports annual subscriptions. Highlight "Most Popular" or "Best Value" on annual plans.

7. Integration & Performance Risks

■ RISK

No Fallback if Sarvam AI Voice API Fails

If Sarvam AI API is down, quota exceeded, or key expires, patients receive silence — no voice note, no error message, no fallback. The queue flow continues silently without the voice confirmation the patient expected.

Fix: Wrap Sarvam API call in try-catch. On failure: log the error, skip voice note gracefully, send a plain text WhatsApp message instead as fallback. Add a Vercel alert when Sarvam errors exceed 5 per hour.

■ RISK

Interakt 24-Hour Session Expiry Not Handled

When your backend sends 10-away or 5-away alerts, it assumes patient session is still active. If patient did not message within 24 hours, Interakt rejects the message silently. Your logs show no error and doctor dashboard shows no indication of failed alert.

Fix: Check Interakt API response for session expiry error codes. On failure: log it as "session_expired" in Supabase, add a flag on the patient record. Optionally try sending via approved template as fallback.

■ RISK

Landing Page Pricing Misleads Clinic Owners

The pricing section currently says "All plans include every feature" but your actual plans have strict feature tiers. Starter shows only 4 features. This contradiction between landing page and actual product will cause trust issues and support complaints after purchase.

Fix: Update pricing section immediately to show accurate features per plan. Remove "All plans include every feature" text. Match exactly what is in your subscription_plans.md. This is also a legal consumer protection issue.

8. Complete Fix Priority Order

#	Task	Time	When
1	Replace webhook secret with strong random key (openssl rand -hex 32)	5 mins	TODAY
2	Add rate limiting to /api/auth/login — max 5 attempts per IP per 15 mins	2 hrs	TODAY
3	Enable Supabase RLS on patients + clinics tables	1 hr	THIS WEEK
4	Fix landing page pricing — remove "All plans include every feature"	30 mins	THIS WEEK
5	Add input sanitization on name + rating fields in API routes	1 hr	THIS WEEK
6	Enforce subscription plan patient limits in /api/whatsapp join action	1 hr	THIS WEEK
7	Add Sarvam AI fallback to text message when voice note fails	1 hr	THIS WEEK
8	Add custom 404 page with TokenPe branding	30 mins	THIS WEEK
9	Add loading state to login button to prevent double submission	20 mins	THIS WEEK
10	Add Forgot PIN recovery flow via WhatsApp OTP	3 hrs	THIS WEEK
11	Fix dashboard mobile responsiveness — test on 375px width	2 hrs	THIS WEEK
12	Add React error boundary on dashboard for Supabase disconnects	1 hr	WHEN FREE
13	Submit sitemap to Google Search Console for indexing	30 mins	WHEN FREE
14	Add Open Graph meta tags for social media sharing preview	30 mins	WHEN FREE
15	Add cookie consent banner	2 hrs	WHEN FREE
16	Add complete corporate address in Terms of Service	5 mins	WHEN FREE
17	Add clear refund policy timeline to Terms	15 mins	WHEN FREE

18	Set up professional email: support@tokenpe.online	10 mins	WHEN FREE
19	Add annual billing option in Razorpay + billing page	3 hrs	WHEN FREE
20	Handle Interakt 24-hr session expiry in alert sending	1 hr	WHEN FREE

9. Overall Verdict

TokenPe is production-ready with 2 critical fixes needed first.

Your security architecture — JWT with HttpOnly cookies, IDOR protection, PIN triple-auth, masked logs, and 3-join limit per phone — is better than most Indian SaaS apps at this stage. You have clearly thought about security seriously.

Fix the webhook secret and add login rate limiting TODAY. These take under 3 hours combined. Then work through the "This Week" items before your first paying clinic. The SEO, legal, and business items can be done gradually over the next month.

Safe to demo to clinics right now. Safe to accept payments after fixing items 1-9.

Report generated by automated + manual audit of tokenpe.online — May 2026

For questions: tokenpe.app@gmail.com | tokenpe.online